

CYBERSECURITY INTERNSHIP

Name: Hammad Rasheed

ID: DHC-5590

Week 3

Advanced Security & Final Reporting

1. Basic Penetration Testing with Nmap

Scan Open Ports

```
nmap -p- 127.0.0.1
```

Service Detection

```
nmap -sV -p 3000 127.0.0.1
```

Vulnerability Scan

```
nmap --script http-vuln* -p 3000 127.0.0.1
```

2. Cracking Weak Hashes

Hashcat

```
hashcat -m 0 -a 0 hashes.txt rockyou.txt
```

John the Ripper

```
john --format=raw-md5 --wordlist=rockyou.txt hashes.txt
```

3. JWT Manipulation

Brute Force JWT Secret

```
hashcat -m 16500 -a 0 jwt.txt rockyou.txt
```

4. Logging with Winston

Install

```
npm install winston
```

Example Logger

```
const winston = require('winston');

const logger = winston.createLogger({
  level: 'info',
  transports: [
    new winston.transports.Console(),
    new winston.transports.File({
      filename: 'security.log'
    })
  ]
});
```

```
]
});
```

Log Failed Login Attempts

```
logger.warn('Failed login attempt', {
  email,
  ip: req.ip
});
```

Final Security Checklist

#	Best Practice	Status	Notes
1	Input Validation	✓	Validate all inputs
2	Output Encoding	✓	Escape HTML entities
3	Parameterized Queries	✓	Avoid raw SQL
4	Password Hashing	✓	Use bcrypt
5	JWT Security	✓	Strong secrets + expiry
6	HTTPS/TLS	✓	Enforce HTTPS
7	Security Headers	✓	Use Helmet.js
8	Access Control	✓	RBAC implementation
9	CORS Configuration	✓	Restrict origins
10	Rate Limiting	✓	Protect login/API
11	Error Handling	✓	Generic messages
12	Logging & Monitoring	✓	Monitor suspicious activity
13	Session Management	✓	Secure cookies
14	Dependency Scanning	✓	Run npm audit
15	CSRF Protection	✓	Use CSRF tokens

Quick Reference — Key Challenges & Solutions

Challenge	Method	Payload / Technique
Score Board	URL Guess	/#/score-board
Login Admin	SQLi	' OR 1=1;--
DOM XSS	Search Bar	<iframe src="javascript:alert('xss')">
Admin Section	Navigation	/#/administration
Confidential Document	Path Traversal	ftp/legal.md
Error Handling	Invalid Input	' in login field
Exposed Credentials	OSINT	Inspect JS files
Zero Stars	Burp Interception	Rating = 0
Forged Feedback	IDOR	Modify UserId
View Basket	IDOR	Modify BasketId
